

SENTINAL SECURITY AUDIT REPORT

Target Scope: None | Scan Mode: STANDARD | Auth: DEV_MODE | Date: September 10, 2026 at 09:40 UTC

Security Score	DAST Coverage	Critical Flaws	High Flaws	Total Findings
97.3/100	100.0% (NOT_APPLICABLE)	68	26	106

2. Executive Summary

****Security Assessment Executive Summary****

****Overall Posture:**** CRITICAL POSTURE

The automated assessment of None identified immediate critical exposures requiring urgent remediation. A total of 106 findings were recorded, including 68 Critical and 26 High severity vulnerabilities.

****Key Risk Highlights:****

- Total Discovered Findings: 106 (Critical: 68, High: 26, Medium: 12, Low: 0)
- Correlated Exploit Chains: 0
- Primary Concern Areas: Cryptographic Failures, Insecure Deserialization, Injection

Leadership is advised to authorize immediate sprint allocation for remediation of critical issues and enforce automated security gating in CI/CD pipelines.

4. Prioritized Vulnerability & Threat Inventory

Severity & Risk	Engine	Vulnerability & Threat Scenario	Location & Remediation
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential SQL Injection via Unsanitized Query Execution Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	sync_sentinal_db.py Fix: Use parameterized queries (e.g. <code>`cursor.execute('SELECT * FROM users WHERE id = %s', (user_id,))`</code>) or an ORM with parameter binding...
MEDIUM Risk: 49.5/100 Blast: Information Disclosure &	SAST sentinal-sast	Use of Broken/Weak Cryptographic Hash (MD5 / SHA-1) Threat: The vulnerability exposes implementation details, internal software versions, or unhardened endpoints that assist attackers in reconnaissance and multi-stage attack chaining...	sync_sentinal_db.py Fix: Use SHA-256 / SHA-3 for hashing or Argon2 / bcrypt / PBKDF2 for password storage...
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential SQL Injection via Unsanitized Query Execution Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	SENTINAL/backend/app/scanners/sast/sast_engine.py Fix: Use parameterized queries (e.g. <code>`cursor.execute('SELECT * FROM users WHERE id = %s', (user_id,))`</code>) or an ORM with parameter binding...
CRITICAL Risk: 99.0/100 Blast: Information Disclosure &	SAST sentinal-sast	Insecure Deserialization via Pickle / Unsafe YAML Threat: The vulnerability exposes implementation details, internal software versions, or unhardened endpoints that assist attackers in reconnaissance and multi-stage attack chaining...	SENTINAL/backend/app/scanners/sast/sast_engine.py Fix: Use <code>`yaml.safe_load()`</code> or JSON for data serialization instead of pickle...
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential SQL Injection via Unsanitized Query Execution Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	SENTINAL/backend/tests/test_e2e_assessment.py Fix: Use parameterized queries (e.g. <code>`cursor.execute('SELECT * FROM users WHERE id = %s', (user_id,))`</code>) or an ORM with parameter binding...

HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential SQL Injection via Unsanitized Query Execution Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	SENTINAL/backend/tests/test_scanners.py Fix: Use parameterized queries (e.g. <code>`cursor.execute('SELECT * FROM users WHERE id = %s', (user_id,))`</code>) or an ORM with parameter binding...
MEDIUM Risk: 42.1/100 Blast: Information Disclosure &	SAST sentinal-sast	Dockerfile Container Running as Root Threat: The vulnerability exposes implementation details, internal software versions, or unhardened endpoints that assist attackers in reconnaissance and multi-stage attack chaining...	SENTINAL/docker/Dockerfile.backend Fix: Add <code>`USER nonroot`</code> or a dedicated unprivileged user before the ENTRYPOINT/CMD...
MEDIUM Risk: 42.1/100 Blast: Information Disclosure &	SAST sentinal-sast	Dockerfile Container Running as Root Threat: The vulnerability exposes implementation details, internal software versions, or unhardened endpoints that assist attackers in reconnaissance and multi-stage attack chaining...	SENTINAL/docker/Dockerfile.frontend Fix: Add <code>`USER nonroot`</code> or a dedicated unprivileged user before the ENTRYPOINT/CMD...
HIGH Risk: 86.6/100 Blast: Session Hijacking & Clie	SAST sentinal-sast	Cross-Site Scripting (XSS) via innerHTML / dangerouslySetInnerHTML Threat: An adversary can inject malicious JavaScript into the victim's browser session, stealing session tokens and cookies, rewriting web pages for credential phishing, or forcing unautho..	SENTINAL/frontend/src/api/mockData.js Fix: Use <code>`textContent`</code> or sanitize user input using DOMPurify before inserting into the DOM...
MEDIUM Risk: 42.1/100 Blast: Information Disclosure &	SAST sentinal-sast	Dockerfile Container Running as Root Threat: The vulnerability exposes implementation details, internal software versions, or unhardened endpoints that assist attackers in reconnaissance and multi-stage attack chaining...	vajra Finl/indigo 2/indigo/new/INDIGO/Dockerfile Fix: Add <code>`USER nonroot`</code> or a dedicated unprivileged user before the ENTRYPOINT/CMD...
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential SQL Injection via Unsanitized Query Execution Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	vajra Finl/indigo 2/indigo/new/INDIGO/backe nd/services/gemini_service.py Fix: Use parameterized queries (e.g. <code>`cursor.execute('SELECT * FROM users WHERE id = %s', (user_id,))`</code>) or an ORM with parameter binding...
CRITICAL Risk: 100.0/100 Blast: Full Server Takeover & R	SAST sentinal-sast	Command Injection via Unsanitized Shell Execution Threat: An adversary can execute arbitrary operating system commands with web process privileges, allowing them to spawn reverse shells, install backdoors/ransomware, and pivot laterally i..	vajra Finl/indigo 2/indigo/new/INDIGO/backe nd/services/gemini_service.py Fix: Pass command arguments as a list with <code>`shell=False`</code> and validate/sanitize all inputs...
MEDIUM Risk: 42.1/100 Blast: Information Disclosure &	SAST sentinal-sast	Dockerfile Container Running as Root Threat: The vulnerability exposes implementation details, internal software versions, or unhardened endpoints that assist attackers in reconnaissance and multi-stage attack chaining...	vajra Finl/indigo 2/indigo/new/INDIGO/frontend/Dockerfile Fix: Add <code>`USER nonroot`</code> or a dedicated unprivileged user before the ENTRYPOINT/CMD...
HIGH Risk: 86.6/100 Blast: Session Hijacking & Clie	SAST sentinal-sast	Cross-Site Scripting (XSS) via innerHTML / dangerouslySetInnerHTML Threat: An adversary can inject malicious JavaScript into the victim's browser session, stealing session tokens and cookies, rewriting web pages for credential phishing, or forcing unautho..	vajra Finl/indigo 2/indigo/new/INDIGO/fronte nd/public/domain-analysis/app.js Fix: Use <code>`textContent`</code> or sanitize user input using DOMPurify before inserting into the DOM...
HIGH Risk: 86.6/100 Blast: Session Hijacking & Clie	SAST sentinal-sast	Cross-Site Scripting (XSS) via innerHTML / dangerouslySetInnerHTML Threat: An adversary can inject malicious JavaScript into the victim's browser session, stealing session tokens and cookies, rewriting web pages for credential phishing, or forcing unautho..	vajra Finl/indigo 2/indigo/new/INDIGO/fronte nd/src/sentina/api/mockData.js Fix: Use <code>`textContent`</code> or sanitize user input using DOMPurify before inserting into the DOM...

MEDIUM Risk: 54.5/100 Blast: Third-Party Component Ex	SCA osv-scanner	Vulnerable Dependency: uvicorn (latest) - GHSA-33c7-2mpw-hg34 Threat: An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..	SENTINAL/backend/requirements.txt Fix: Upgrade python-multipart to a secure version. Upgrade to latest version...
MEDIUM Risk: 54.5/100 Blast: Third-Party Component Ex	SCA osv-scanner	Vulnerable Dependency: esbuild (0.21.5) - GHSA-67mh-4wv8-2f99 Threat: An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..	SENTINAL/frontend/package-lock.json Fix: Upgrade esbuild to a secure version. Upgrade to latest version...
MEDIUM Risk: 54.5/100 Blast: Third-Party Component Ex	SCA osv-scanner	Vulnerable Dependency: vite (5.1.6) - GHSA-356w-63v5-8wf4 Threat: An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..	SENTINAL/frontend/package.json Fix: Upgrade vite to a secure version. Upgrade to latest version...
MEDIUM Risk: 54.5/100 Blast: Third-Party Component Ex	SCA osv-scanner	Vulnerable Dependency: fastapi (0.104.1) - PYSEC-2024-38 Threat: An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..	vajra Finl/indigo 2/indigo/new/INDIGO/backend/requirements.txt Fix: Upgrade python-multipart to a secure version. Upgrade to latest version...
MEDIUM Risk: 54.5/100 Blast: Third-Party Component Ex	SCA osv-scanner	Vulnerable Dependency: brace-expansion (5.0.7) - GHSA-mh99-v99m-4gvg Threat: An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..	vajra Finl/indigo 2/indigo/new/INDIGO/frontend/package-lock.json Fix: Upgrade baseline-browser-mapping to a secure version. Upgrade to latest version...
MEDIUM Risk: 54.5/100 Blast: Third-Party Component Ex	SCA osv-scanner	Vulnerable Dependency: axios (1.6.0) - GHSA-35jp-ww65-95wh Threat: An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..	vajra Finl/indigo 2/indigo/new/INDIGO/frontend/package.json Fix: Upgrade postcss to a secure version. Upgrade to latest version...
CRITICAL Risk: 100.0/100 Blast: Cloud & Third-Party Serv	SECRETS gitleaks	Exposed Secret: AWS Access Key ID Threat: Hardcoded credentials, API keys, or private cryptographic keys exposed in code or public responses allow adversaries to authenticate directly to third-party SaaS services, cloud ac..	sentinal.db Fix: Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or BFG, and store secrets in environment v..
HIGH Risk: 94.3/100 Blast: Cloud & Third-Party Serv	SECRETS gitleaks	Exposed Secret: Database Connection String with Password Threat: Hardcoded credentials, API keys, or private cryptographic keys exposed in code or public responses allow adversaries to authenticate directly to third-party SaaS services, cloud ac..	SENTINAL/.env.example Fix: Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or BFG, and store secrets in environment v..
CRITICAL Risk: 100.0/100 Blast: Cloud & Third-Party Serv	SECRETS gitleaks	Exposed Secret: AWS Access Key ID Threat: Hardcoded credentials, API keys, or private cryptographic keys exposed in code or public responses allow adversaries to authenticate directly to third-party SaaS services, cloud ac..	SENTINAL/sentinal.db Fix: Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or BFG, and store secrets in environment v..
CRITICAL Risk: 100.0/100 Blast: Cloud & Third-Party Serv	SECRETS gitleaks	Exposed Secret: AWS Access Key ID Threat: Hardcoded credentials, API keys, or private cryptographic keys exposed in code or public responses allow adversaries to authenticate directly to third-party SaaS services, cloud ac..	SENTINAL/backend/sentinal.db Fix: Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or BFG, and store secrets in environment v..

5. Strategic Remediation Playbook

****Step-by-Step Remediation Actions:****

- ****Insecure Deserialization:**** Use ``yaml.safe_load()`` or JSON for data serialization instead of pickle.
- ****Remote Code Execution:**** Pass command arguments as a list with ``shell=False`` and validate/sanitize all inputs.
- ****Cloud Credentials:**** Immediately revoke/rotate the leaked credential, remove it from git history using `git-filter-repo` or BFG, and store secrets in environment variables or a Secret Vault.